

Security Assessment Report (Penetration Test)

Scenario and Tools

After months of working on his business idea, Mike is finally ready to launch his website. He has invested a significant amount of time and effort in developing a product that he believes users will love. However, Mike is also aware that businesses of all sizes are targeted by attackers daily. Before going live, he wants reassurance that no sensitive or unintended pages have been left publicly accessible. You've been asked to perform an assessment of his web application and identify any exposed areas that could pose a security risk. Your goal is to find these weaknesses before real attackers do, and help Mike launch with confidence. When you're ready, click the **View Site** button above to access the web application and begin your assessment.

Project: [TryHackMe | Become a Hacker](#)

Auditor: David

Date: February 26, 2026

Version: 1

1. Executive Summary

We performed a security assessment for <http://www.onlineshop.thm/> webpage and discovered several vulnerabilities that a potential visitor/threat could take advantage of to access admin account and disrupt the webpage functionalities. A hidden login webpage was found after running a webpage scanner and in this page, the admin account was not properly configured and had a weak password.

2. Scope & Methodology

- **Target:** <http://www.onlineshop.thm/>

- **Methodology:**

We are going to try and find weaknesses , and hidden pages.

Black-box penetration testing focused on directory discovery and authentication bypass

- **Tools Used:** SQL INJECTIONS , Gobuster (webpage scanner)
-

3. Vulnerability Analysis

Finding #1: Sensitive Directory Exposure / Broken Access Control

- **Severity:** high
- **Location:** URL address

A. Description

By using Gobuster, we were able to find a hidden login page

B. Proof of Concept (PoC)

```
user@thm ~> gobuster dir --url http://www.onlineshop.thm/ -w  
/usr/share/wordlists/dirbuster/directory-list.txt
```

Gobuster v3.6

```
[+] Url: http://www.onlineshop.thm/  
[+] Method: GET  
[+] Wordlist: directory-list.txt  
[+] Negative Status codes: 404
```

Starting gobuster in directory enumeration mode

```
/login (Status: 200) [Size: 314]
```

```
Progress: 87664 / 87665 (100.00%)
```

```
Finished
```

C. Impact

Unauthorized access may be possible to attempt brute force login and other possibilities.

D. Remediation (Solution)

Make the subpage inaccessible by guest other than the admin or those authorized

Finding #2: Broken Authentication / Weak Password Policy

- **Severity:** critical
- **Location:** login page

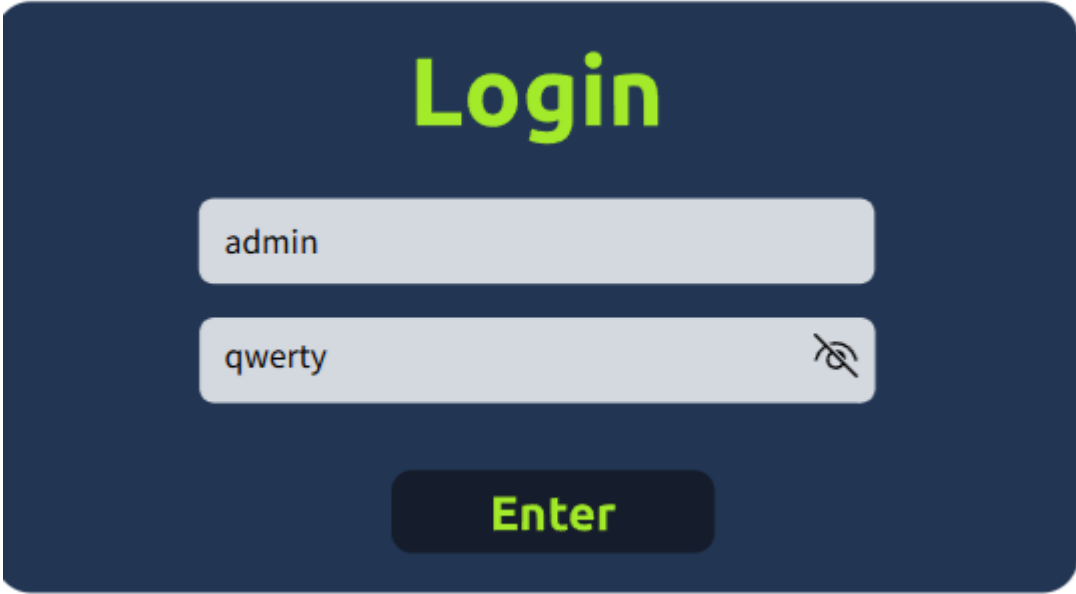
A. Description

After accessing the login page , we tried to log in as admin with weak password such as :

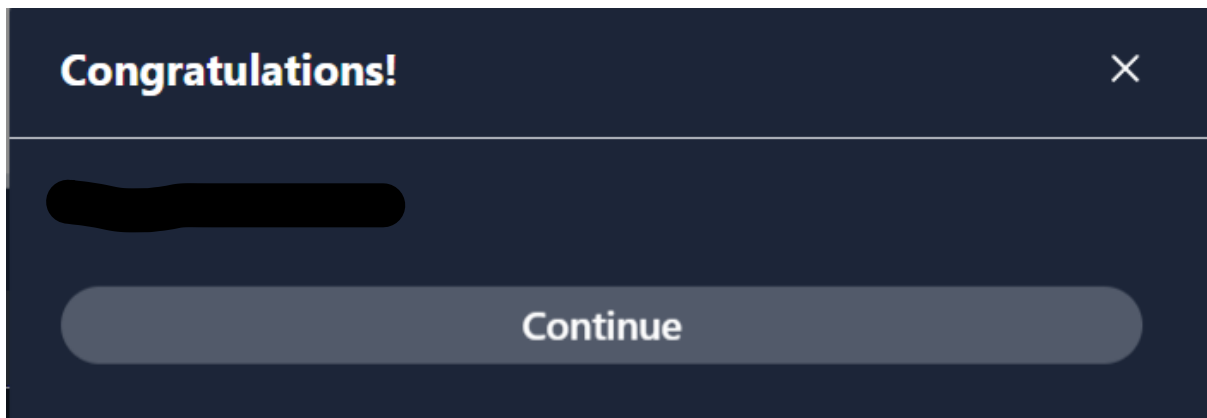
- abc123
- 123456
- password
- qwerty
- 654321

And it worked with qwerty:

B. Proof of Concept (PoC)



The image shows a login interface with a dark blue background. At the top, the word "Login" is written in large, bold, yellow-green letters. Below it, there are two light gray input fields. The first field contains the text "admin". The second field contains the text "qwerty" and has a small icon of an eye with a diagonal line through it to its right, indicating a password field. Below the input fields is a dark blue button with the word "Enter" in yellow-green text.



C. Impact

A success message was displayed confirming our login status.

An admin account was compromised which gave the highest authority to the threat actor

The whole website could be compromised.

D. Remediation (Solution)

We have to add stronger passwords with letters , caps letters , numbers and punctuation .

Add WAF to block access to this page from unknown IPs.

MFA (Multi-Factor Authentication) to add a second layer of protection with either who the user is, what he knows or possess.

Remove admin option to login and use user with less privilege.

4. Conclusion

The assessment of "onlineshop.thm" revealed critical security gaps that could lead to a full business compromise. The combination of an exposed administrative interface and a weak password policy creates an easy path for attackers to gain "Domain Admin" equivalent privileges over the web application.

By implementing the recommended mitigations—specifically hiding administrative directories, enforcing complex password policies, and deploying Multi-Factor Authentication, Mike can significantly harden his website's security posture. Securing these entry points is mandatory before the official public launch to ensure customer data protection and business continuity.

